

CÓMO PROTEGER AGENTES DE IA, SISTEMAS RAG Y SERVIDORES MCP

Manual práctico de seguridad para IA agéntica, generación aumentada por recuperación, herramientas, memoria, identidades y supervisión humana

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

La seguridad humana es lo primero. Este manual está destinado a usos legales, autorizados y defensivos. Los agentes de IA pueden actuar sobre sistemas reales. Realice pruebas solamente en entornos aprobados y exija supervisión humana para acciones de alto impacto.

1. Qué protege este manual

- Agentes de IA que planifican, razonan, utilizan herramientas y ejecutan acciones.
- Canalizaciones RAG que recuperan documentos empresariales o información de bases de datos.
- Hosts, clientes, servidores, herramientas, instrucciones y recursos MCP.
- Memoria del agente, estado de tareas, credenciales, registros y flujos de aprobación.
- Sistemas de uno o varios agentes.

2. Principios fundamentales

- El modelo propone; la lógica confiable de la aplicación autoriza.
- Trate la entrada del usuario, el contenido recuperado, los resultados de herramientas y la memoria como datos no confiables.
- Use identidades únicas y privilegio mínimo.
- Separe capacidades de lectura, escritura, ejecución y administración.
- Exija confirmación explícita para acciones sensibles.
- Registre acciones sin conservar contenido sensible innecesario.
- Diseñe fallas seguras, reversión, apagado y recuperación.

3. Arquitectura de referencia

- El usuario o la aplicación se autentica mediante un proveedor aprobado.
- Una capa de orquestación valida entradas, aplica políticas y conserva el contexto del usuario.
- El agente recibe únicamente las herramientas y los datos necesarios.
- La recuperación RAG aplica permisos de origen en cada consulta.
- Los clientes MCP se conectan solo con servidores aprobados mediante transporte autenticado y cifrado.
- Las acciones de alto impacto pasan por autorización determinista y aprobación humana.
- El monitoreo registra identidad, decisión, herramienta, parámetros, resultado y aprobación.

4. Modelado de amenazas

- Identifique usuarios, agentes, modelos, memoria, índices RAG, herramientas, servidores MCP y servicios externos.
- Identifique cada límite de confianza y cada punto de entrada de instrucciones.
- Documente qué puede leer, modificar, ejecutar, eliminar, enviar, comprar o aprobar cada herramienta.
- Calcule el radio de impacto de una identidad comprometida o una memoria contaminada.
- Identifique a las personas que podrían verse afectadas por acciones incorrectas o no autorizadas.

5. Identidad y autorización

- Asigne una identidad única a cada agente o servicio de producción.
- Prefiera tokens de corta duración, identidades administradas, federación u OAuth.
- No comparta una credencial administrativa entre varios agentes.
- Autorice cada llamada a herramienta en la aplicación y en el servicio de destino.
- Vincule la acción con el usuario iniciador para impedir que el agente exceda sus derechos.
- Revise periódicamente identidades, permisos y credenciales sin uso.

6. Seguridad de herramientas y acciones

- Use listas permitidas de herramientas, métodos, destinos, rutas y clases de datos.
- Valide argumentos estructurados con esquemas estrictos.
- Rechace campos inesperados, acciones ambiguas, fragmentos de comandos y rutas inseguras.
- Aplique límites de frecuencia, tiempo, tamaño y transacción.
- Use vista previa o simulación antes de cambios destructivos.
- Exija aprobación humana para acciones financieras, legales, laborales, de seguridad, eliminación o cambio de privilegios.
- Impida que el modelo cambie sus propios permisos.

7. Protección de RAG

- Aplique autorización en el momento de la consulta.
- Conserve permisos de origen y utilice filtrado de seguridad.
- Registre procedencia, propietario, clasificación, fecha y retención.
- Analice archivos cargados y rechace tipos peligrosos.
- Trate los pasajes recuperados como datos, no como instrucciones confiables.
- Limite el contexto y exija citas.
- Detecte documentos contaminados, inyección indirecta, permisos obsoletos y filtración entre inquilinos.
- Elimine rápidamente contenido revocado o borrado.

8. Protección de memoria y estado

- Separe el estado temporal de la memoria persistente.
- Almacene únicamente información necesaria para un propósito aprobado.
- No guarde secretos, credenciales amplias o datos personales sensibles en la memoria.
- Etiquete la memoria con fuente, propietario, clasificación, confianza y vencimiento.
- Valide la memoria antes de que influya en acciones de alto impacto.
- Permita inspeccionar, corregir y eliminar memoria.

9. Seguridad de MCP

- Mantenga un inventario aprobado de servidores MCP, propietarios, versiones y propósitos.
- Use conexiones autenticadas y cifradas.
- Implemente OAuth 2.1 u otro método aprobado para servidores remotos.
- No use identificadores de sesión como autenticación.
- Use identificadores impredecibles y verifique cada solicitud entrante.
- Valide entradas, aplique acceso, limite llamadas y sanee resultados.
- Muestre al usuario los datos sensibles antes de ejecutar una herramienta.
- Valide resultados antes de entregarlos al modelo.
- Fije dependencias y vigile cambios en servidores de terceros.

10. Inyección de instrucciones y contaminación de herramientas

- Separe instrucciones del sistema, usuario, contenido recuperado, memoria y resultados.
- No permita que documentos o descripciones de herramientas redefinan políticas.
- Trate metadatos y descripciones del servidor como potencialmente maliciosos.
- Detecte intentos de revelar secretos, invocar herramientas ocultas, evitar aprobaciones o redirigir datos.
- Use controles independientes que no puedan anularse con texto.
- Pruebe inyección directa, indirecta, contaminación de descripciones, memoria y cambios maliciosos posteriores.

11. Sistemas multiagente

- Defina qué agente puede delegar, aprobar o finalizar trabajo.
- Evite acumulación de privilegios entre agentes.
- Autentique mensajes y conserve el contexto del usuario original.
- Limite recursión, profundidad, tokens, llamadas y tiempo.
- Detecte instrucciones conflictivas y ciclos.
- Incluya un apagado de emergencia para todo el flujo.

12. Supervisión humana y accesibilidad

- Muestre acciones propuestas, recursos afectados, parámetros, impacto y opciones de reversión.
- Use lenguaje claro y pantallas accesibles.
- No utilice patrones engañosos ni presión artificial.
- Permita cuestionar, corregir o apelar resultados importantes.
- Ofrezca alternativas compatibles con tecnologías de asistencia.
- Exija revisión humana capacitada cuando los errores puedan afectar derechos, seguridad, empleo, finanzas o acceso a servicios.

13. Registros, monitoreo y detección

- Registre usuario, identidad del agente, versión, herramienta, parámetros, resultado, aprobación y hora.
- Monitoree secuencias extrañas, denegaciones repetidas, recuperación masiva, cambios de privilegio y servidores nuevos.
- Alerta sobre acceso a datos sensibles, controles deshabilitados, destinos inesperados y transferencias grandes.
- Proteja los registros y defina retención según riesgo y privacidad.
- Evite almacenar instrucciones y resultados completos sin necesidad justificada.

14. Pruebas y red teaming

- Pruebe solamente con autorización escrita y alcance definido.
- Pruebe filtración entre usuarios e inquilinos.
- Pruebe inyección directa e indirecta.
- Pruebe abuso de herramientas, parámetros, comandos y delegación.
- Pruebe memoria, documentos, descripciones y servidores MCP contaminados.
- Pruebe denegación de servicio, ciclos, costos y autonomía excesiva.
- Registre comportamiento esperado, resultado, severidad, responsable, corrección y nueva prueba.

15. Respuesta a incidentes

- Desactive el agente, herramienta, servidor MCP, identidad o conector afectado.
- Conserve registros, memoria, instrucciones, fuentes, resultados y versiones.
- Revoque tokens y rote secretos.
- Elimine contenido contaminado y reconstruya índices o memoria cuando sea necesario.
- Evalúe acciones no autorizadas, exposición y daño a personas.
- Notifique según política y ley.
- Vuelva a probar antes de restaurar.

16. Gobierno y evidencia

- Mantenga inventario de agentes, RAG, servidores MCP, herramientas, propietarios, datos y niveles de riesgo.
- Documente propósito, usos prohibidos, supervisión humana y autoridad de apagado.
- Conserve diagramas, flujos, amenazas, evaluaciones y aceptaciones de riesgo.
- Revise proveedores, componentes de código abierto, modelos y servidores MCP.
- Mapee controles a NIST AI RMF, NIST CSF, OWASP y requisitos aplicables.

17. Plan de 30, 60 y 90 días

- Días 1 a 30: inventariar, identificar propietarios, retirar agentes abandonados, activar registros y eliminar accesos excesivos.
- Días 31 a 60: identidades únicas, privilegio mínimo, filtrado RAG, autorización MCP, listas permitidas y aprobaciones.
- Días 61 a 90: pruebas adversarias, monitoreo, ejercicios de incidentes, automatización de evidencia y revisiones periódicas.

18. Lista de preparación para producción

- ☐ Propietarios empresarial y técnico identificados
- ☐ Propósito aprobado y usos prohibidos
- ☐ Inventario de agentes, RAG, MCP, herramientas y datos
- ☐ Modelo de amenazas revisado
- ☐ Identidades únicas y privilegio mínimo
- ☐ Autorización RAG en tiempo de consulta probada
- ☐ Autorización MCP y sesiones seguras
- ☐ Esquemas, listas permitidas y límites de herramientas
- ☐ Aprobación humana para acciones de alto impacto
- ☐ Pruebas de inyección y contaminación
- ☐ Registros, alertas y controles de privacidad
- ☐ Apagado de emergencia y reversión probados
- ☐ Respuesta a incidentes ejercitada
- ☐ Accesibilidad y apelación revisadas
- ☐ Aprobación final de seguridad registrada

19. Ejemplo de registro de riesgos

Riesgo	Impacto	Controles	Responsable
Documento RAG contaminado modifica el comportamiento	Exposición de datos o uso no autorizado	Validación, separación de instrucciones, autorización y pruebas	Propietario de plataforma

Servidor MCP de terceros cambia su comportamiento	Transferencia inesperada o acción destructiva	Inventario, versiones, autorización, validación y monitoreo	Propietario de integración
Agente con privilegios excesivos	Radio de impacto amplio	Identidad única, privilegio mínimo, aprobaciones y revisión	Ingeniería de seguridad

20. Referencias oficiales

- OWASP Agentic AI Threats and Mitigations: <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>
- OWASP Securing Agentic Applications Guide: <https://genai.owasp.org/resource/securing-agentic-applications-guide-1-0/>
- OWASP Top 10 for Agentic Applications 2026: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- Model Context Protocol Security Best Practices: https://modelcontextprotocol.io/docs/tutorials/security/security_best_practices
- MCP Authorization: <https://modelcontextprotocol.io/docs/tutorials/security/authorization>
- MCP Tool Security Considerations: <https://modelcontextprotocol.io/specification/2025-06-18/server/tools>
- NIST AI RMF: <https://www.nist.gov/itl/ai-risk-management-framework>
- NIST AI RMF Generative AI Profile: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
- Microsoft Security Planning for LLM Applications: <https://learn.microsoft.com/ai/playbook/technology-guidance/generative-ai/mlops-in-openai/security/security-plan-llm-application>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Distribuido bajo la licencia CC BY-NC-SA 4.0.